

POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO & DEFESA ATIVA

SISTEMA ANTIFRAUDE DE AUTENTICAÇÃO E CIFRAGEM DE DADOS SIMÉTRICA EM CONFORMIDADE COM A LGPD

Discente: **Pedro** | Orientador: **Prof. Fabiano** | Projeto Integrador 2026

1. INTRODUÇÃO & ESCOPO CIBERDEFENSIVO

Ameaça Global: Vazamentos de credenciais corporativas e falhas básicas de autenticação constituem 80% dos vetores de intrusão industrial modernos.

Desafio Técnico: Consolidar uma barreira multicamadas capaz de repelir tentativas online de força bruta, interceptação em rede e vazamento de persistência, respeitando os direitos civis de privacidade da **LGPD (Lei 13.709/2018)**.

Objetivo: Mitigar riscos através da arquitetura de segurança por omissão (*Secure by Default*).

2. GESTÃO CRÍTICA DE CREDENCIAIS E 2FA

MÉTRICA Bcrypt Custo 12: Substituição de hashes simples por derivação adaptativa lenta com salt pseudoaleatório embutido de 128 bits. Tempo computacional intencional de **250ms** por hash inviabiliza ataques de dicionário offline e rainbow tables.

TRAVA Rate Limiting Ativo: Algoritmo de controle de taxa síncrono que bloqueia preventivamente o login por **15 minutos** após a 5ª falha de autenticação consecutiva.

MFA Duplo Fator (2FA): Segmentação lógica obrigatória em duas etapas síncronas. O token dinâmico de 6 dígitos (TOTP) é exigido imediatamente após a validação da senha de texto.

3. MECANISMO DE RECUPERAÇÃO DE SENHA

Segurança Padrão OWASP: Processo estruturado contra sequestro de contas que elimina o uso vulnerável de perguntas secretas.

Alta Entropia: Emissão de tokens de segurança dinâmicos gerados via PRNG seguro utilizando o módulo nativo `crypto.randomBytes(32)`.

Ciclo Efêmero: Tempo de expiração severo estrito de **15 minutos** associado ao gatilho de **invalidação pós-uso imediata** em banco de dados, neutralizando ataques de repetição.

4. ENGENHARIA CRIPTOGRÁFICA DE TRÁFEGO

Trânsito Cifrado: Imposição mandatória de criptografia assimétrica de rede via protocolo **TLS/HTTPS**. Middlewares interceptam conexões puras e realizam a rejeição ativa de payloads não cifrados.

[Canal TLS] → [Bcrypt Salt único] → [Rate-Limit Check] → [MFA TOTP] → [Sessão Segura]

Repouso Seguro (AES-256-GCM): Cifragem simétrica de campos sensíveis de identificação pessoal (CPF). O modo GCM provê criptografia autenticada gerando um **Vetor de Inicialização (IV)** único e uma **Tag de Autenticação** que impede fraudes de injeção ou adulteração nos blocos físicos do banco de dados.

5. GOVERNANÇA E ADEQUAÇÃO LGPD

Minimização: Coleta otimizada restrita ao núcleo transacional, amparada pelas bases legais de Execução de Contrato e Obrigação de Segurança.

Rastreabilidade de Consentimento: Gravação indelével contendo timestamp ISO, e-mail do titular e versão exata das políticas aceitas.

Endpoints de Direitos: Rotas de conformidade implementadas e validadas para extração de dados estruturados (Portabilidade JSON) e remoção completa das tabelas (Direito ao Esquecimento).

6. AUDITORIA POR LOGS & CONCLUSÃO

Tratamento de Logs: Geração automatizada de trilhas de auditoria imutáveis com timestamps padronizados para todos os eventos de risco (sucesso, falha, bloqueios de taxa e geração de tokens), blindando o sistema sob privilégio mínimo.

Conclusão: Os testes funcionais comprovaram resiliência absoluta das contra-medidas, chaves mestres mantidas isoladas em variáveis externas de ambiente, resultando em uma arquitetura de alta confiabilidade em conformidade técnica e regulatória.